Demystifying Privileged Identity Management - Part 1

trimarcsecurity.com/hub-post/demystifying-privileged-identity-management-part-1

Brandon Colley June 5, 2024

Updated: Dec 13, 2024

Words are hard.

English is hard.

IT professionals could probably spend hours independently discussing the words Privileged, Identity, and Management. When Microsoft shoved these three together, I'm not even sure they knew what it meant. Even after we all agree on what Privileged Identity Management (PIM) is, we're left arguing about licensing requirements. We fight about the difference between "eligible" and "permanent" membership. We contest what it means to be "directly assigned" and we question what makes a group "role-assignable". Azure can be confusing. Or do we call it Entra now?

This article series attempts to dissect the terms we throw around when talking about PIM. In Part 1 we break down confusing terminology and hopefully make it easier to understand. Trimarc has assessed hundreds of environments and while PIM implementation has become more prevalent, we still see it deployed in its default configuration. Unfortunately, the default is simply a glorified place to manage group membership. If you're looking to learn the basics of PIM or want to see how PIM can be used to improve your security posture keep reading.

License Requirements

Dollar signs, right out of the gate! Yes, PIM comes with a price tag, but you don't need to license the whole tenant. Microsoft only requires a license of Entra ID P2 or Entra ID Governance for users utilizing the benefits of PIM. A full license breakdown can be found here but the short of it is that a license is only required when a user falls into one of the following categories:

• Users with eligible assignment to Microsoft Entra ID or Azure roles

• Users with time-bound active assignment to Microsoft Entra ID or Azure roles

• Users granted these assignments through role-assignable groups

• Owners of role-assignable groups associated with a Microsoft Entra ID or Azure role

• Users able to approve/reject activation requests

• Users assigned to perform access reviews

Trimarc's advice is to start small. Purchase a handful of licenses for your Global Admins first. Then start moving onto members of more privileged roles and implementing approval workflows where appropriate. Any specific licensing questions should be directed at your trusted Microsoft partner.

PIM is controlled in the Privileged Identity Management blade. Here, administrators manage access to Microsoft Entra roles, approve activation requests, and audit PIM activity. This blade is also where users view and activate role assignments. Those sentences already include some terms that require explanation.

Definitions

The first terms we need to discuss are "roles" and "assignments". Microsoft Entra (and Azure) privileges are granted through "roles". In simplest terms, a "role" is basically a group. The problem is that Entra ID already has groups. Actually, they have 2 types of groups. But don't get me started. Using the group synonym, an "assignment" would boil down to membership.

There, the easy stuff is out of the way.



Eligible vs. Active Assignment

When adding an assignment to a role, you have two choices for assignment type. “Eligible” and “Active”. An “active” assignment is traditional membership which just means the members always possess the permissions the role is granted. If you aren’t licensed for PIM, all role assignments would be considered “active”. An “eligible” assignment type means the members do NOT always possess the permissions the role is granted.

To gain the permissions, a user must “activate” their “eligible” assignment. Figure 1 shows assignment type selection at the time the assignment is being added.

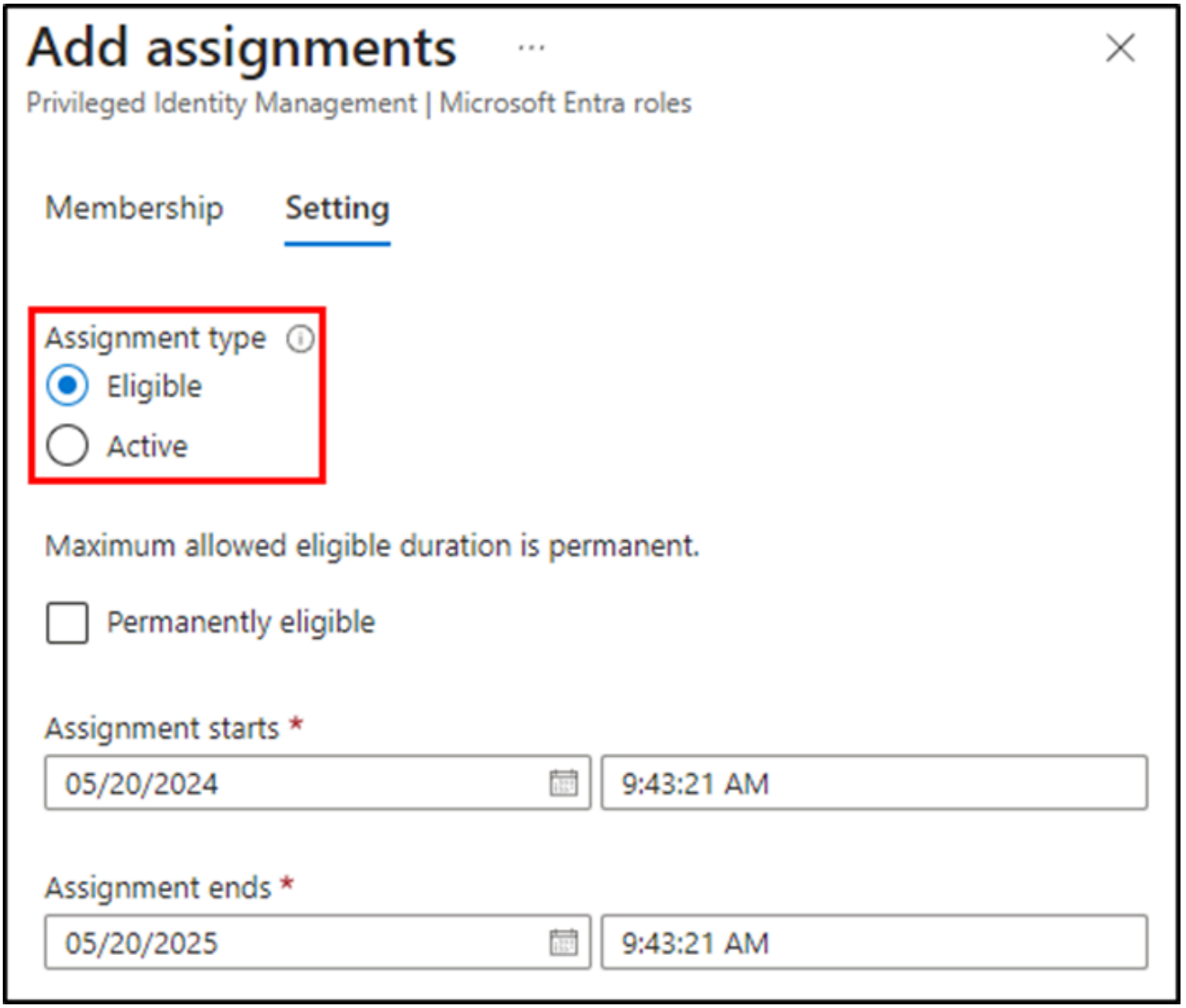
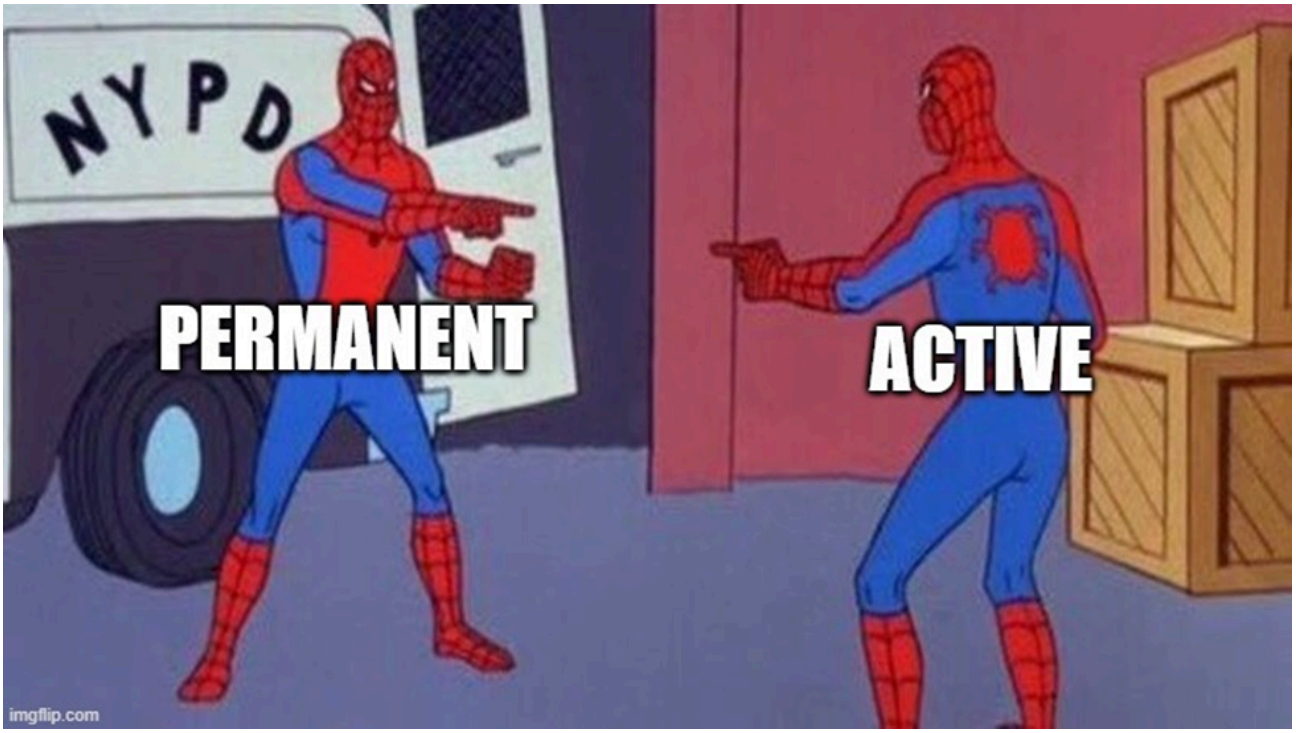


Figure 1

When PIM was first introduced, assignments were either “eligible” or “permanent”. But now, a “permanent” assignment is called an “active” assignment, and the term “permanent” has been repurposed in the context of time-bound assignment duration. Confused yet?



Membership Expiration

Now that we have a handle on eligible and active assignments, let’s talk about expiration. Unlike the old days, saying an assignment is “permanent” is independent of assignment type. A “permanent” assignment does not have an end time and will therefore never expire.

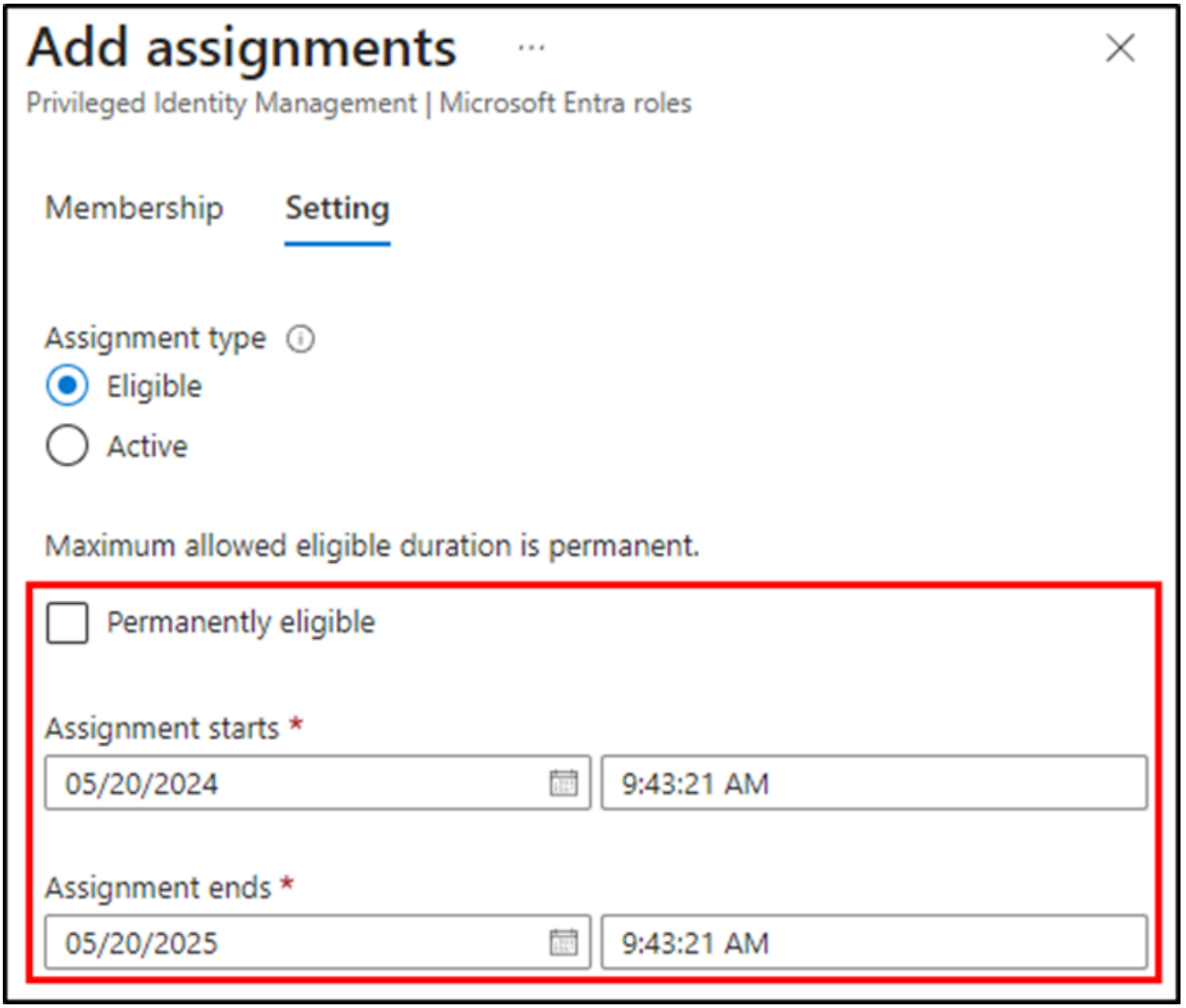


Figure 2

Alternatively, a “time-bound” assignment has a start and end time. Once the assignment reaches the end time, the assignment will expire and appear in the Expired assignments tab. Figure 2 shows the expiration settings configured at the time the assignment is being added.

Direct vs. Group Membership

Assignment type and expiration are assignment configurations that can be applied to both users and groups. That’s right, Microsoft brought nested group membership to the cloud. This concept can be a tough one to fully grasp so I’m breaking it down into a few parts.

First let’s talk about “Direct” membership. It’s easier to think about this by making up our own term: “Indirect”. Having “Direct” membership in a role means the user is directly added to the role. A group can also have “Direct” membership in a role.

Figure 3 shows these memberships when looking at the role’s assignments. The members of groups would therefore have “indirect” membership in the role. Since this indirect

membership is only possible using groups, it's given a "Group" membership type.

User Interface

To better understand these concepts, we must look at it from a few different angles. For example, Figure 3 shows what Membership looks like from the perspective of the Application Administrator role.

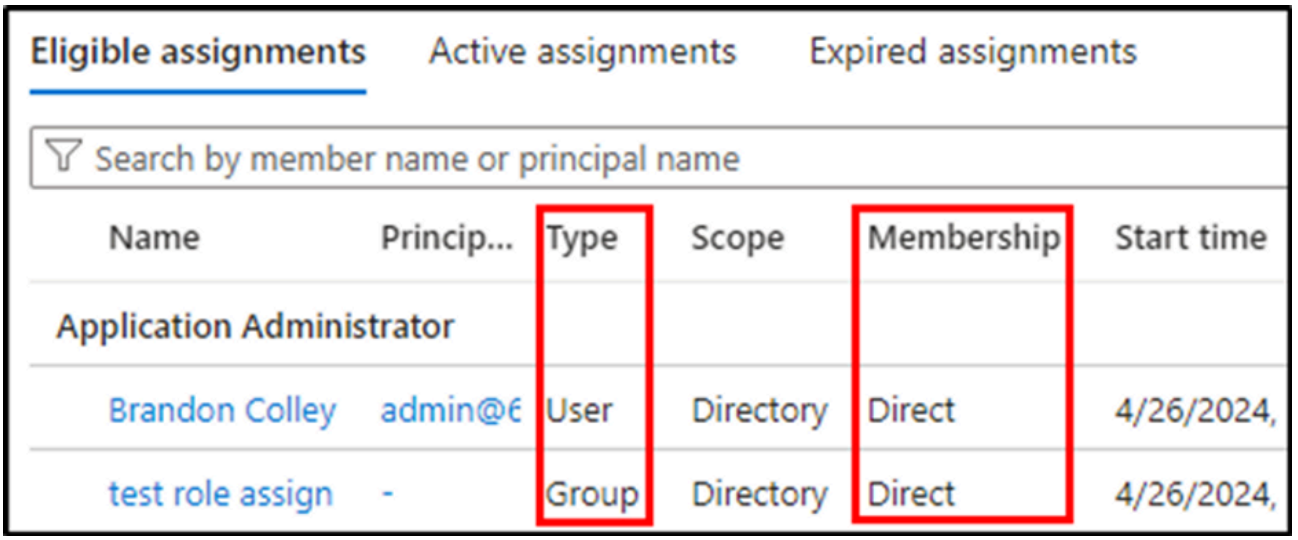


Figure 3

Both Brandon Colley (user) and test role assign (group) have "direct" membership in the Application Administrator role.

Figure 4 shows what Membership looks like from the perspective of AlexW, a member of the "test role assign" group.

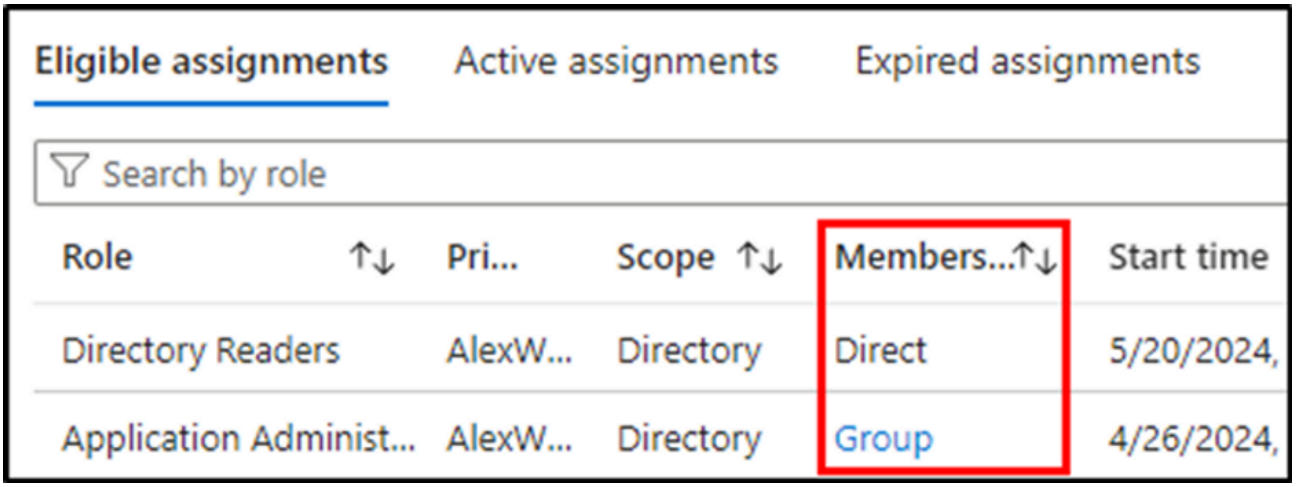


Figure 4

Alex is a "direct" member of the Directory Readers role and is a "group" member of the Application Administrator role. Unfortunately, we need to look a few more places to gain a good understanding of who has rights associated with the Application Administrator role.

Role-Assignable Group

We saw things from the perspective of the role and the user. Now we must examine the group perspective. First, the members tab of the group will tell us anyone else with “indirect” membership in the Application Administrator role. Thank goodness only users can be members of role-assignable groups. This stops the group nesting problem at 1 level deep.

Second, we should check the assigned roles tab to see if the group is a member of any additional roles. The last, and most important, thing to check is the owners tab. Although roles do not have owners, groups do. This is important because the owner of a group can make membership changes.

By now you’re probably ready to hear what we think about all this. Looks like you scrolled down far enough.

Trimarc Recommendation

It depends.

😉

\If that group ownership thing made your spidey-sense tingle, great job. By default, the ability to modify roles and role-assignable groups is reserved for members of Global Administrators and Privileged Role Administrators. Defining an owner for a role-assignable group may be dangerous, as it could provide a method of privilege escalation. That’s why we recommend only using direct assignment for privileged roles.

That said, role-assignable groups do have a place. I have seen environments that utilize a 3rd party service for identity management in which an application is allowed to make modifications to group membership. These processes make onboarding and offboarding extremely simple. Although an automated decommissioning process is a great security benefit, I still believe that highly privileged roles should be heavily limited and managed by hand.

Generally speaking, eligible assignments are preferable to active. Using eligible assignments forces administrators to be more intentional with elevated permissions. They work very well for un-privileged roles where regular user accounts have assignments. They also provide additional security for the highly privileged roles even when dedicated administrator accounts are used.

Most of the benefits associated with eligible assignment come from the configurable role settings that dictate what is required of a user when activating a role. Role settings will be investigated in part 2 of this series. So, you’ll just have to take my word on it for now.

One exception to eligible assignment is for service principals. When using applications that require assignment to roles, they must use active assignment.

Time-based assignments are also preferred in cases where they make sense for your workflow. When a time-based assignment expires, the option to renew becomes available which empowers the user to request extension of the assignment as seen in Figure 5.

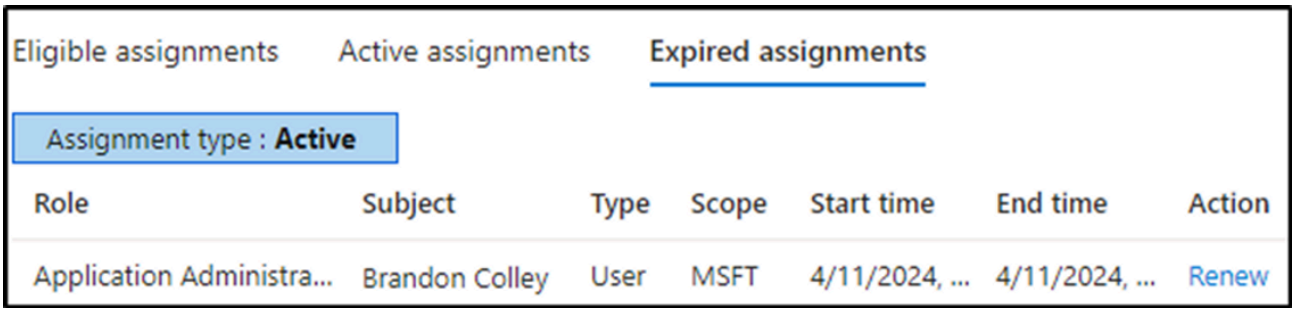


Figure 5

That makes for a good transition to talk more about the end-user perspective. If you're not interested in what the user sees, then you can just scroll to the end for more recommendations. If you want to be a jerk, that is.

The End-User Perspective

Glad to see you're not a jerk! End-user experience is important.

The process of activating PIM role assignments is interesting because in many cases, administrators are also the end-user. The same Privileged Identity Management blade where administrators add assignments and configure roles also contains tasks aimed at the end-user.

The "My roles" link displays information about the user's eligible, active, and expired assignments. If the user wants to activate an eligible assignment, they simply click "Activate" on the desired role. Figure 6 shows a user is eligible to activate three roles. Assigning multiple roles to a privileged user is one method of implementing least-privilege.

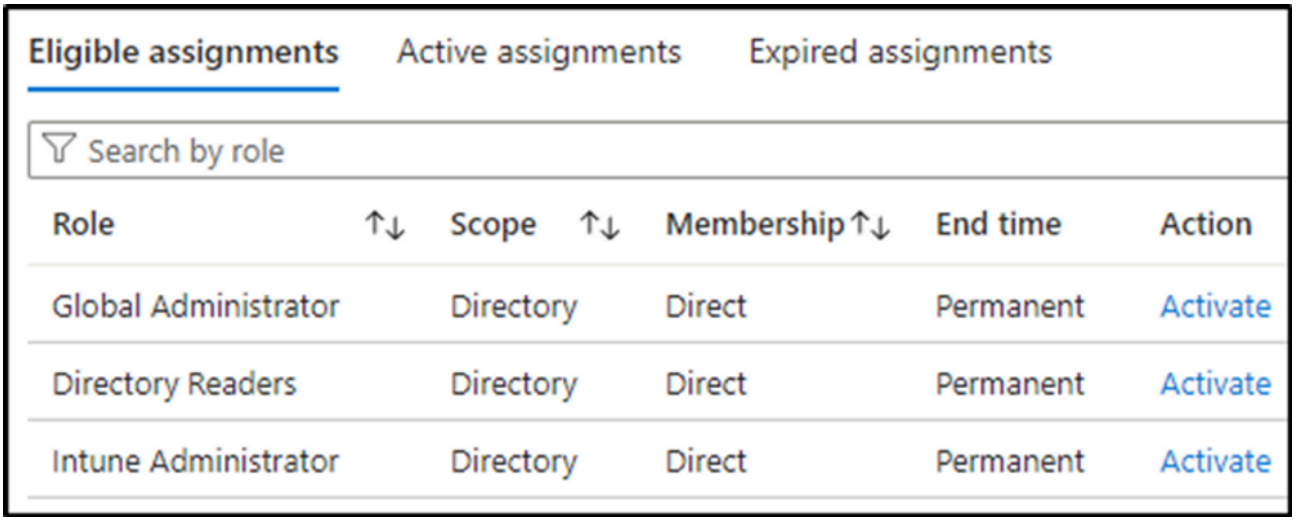


Figure 6

Depending on the role settings (discussed in part 2), the user will be met with prompts to fulfill any requirement for role activation. By default, activation requires a “Reason” and duration seen in Figure 7.

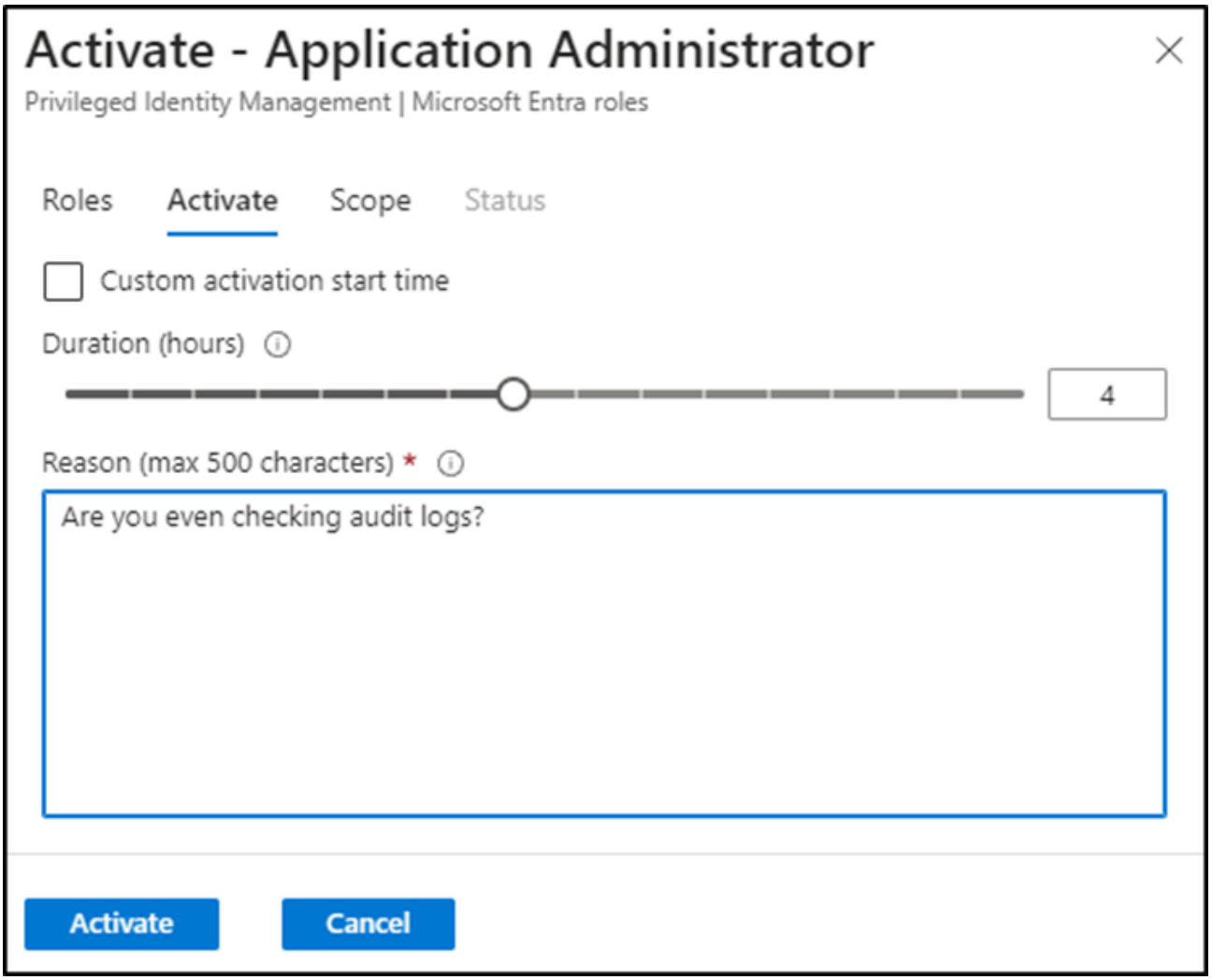


Figure 7

The activation workflow is kicked off, and access is granted after all stages are complete. Once an assignment becomes active, it will appear under the user's Active assignments tab with a state of "Activated". Notice in Figure 8 the difference in "State" between "Global Administrator", the role that was just elevated, and the "Directory Readers" role which was added as an active assignment.

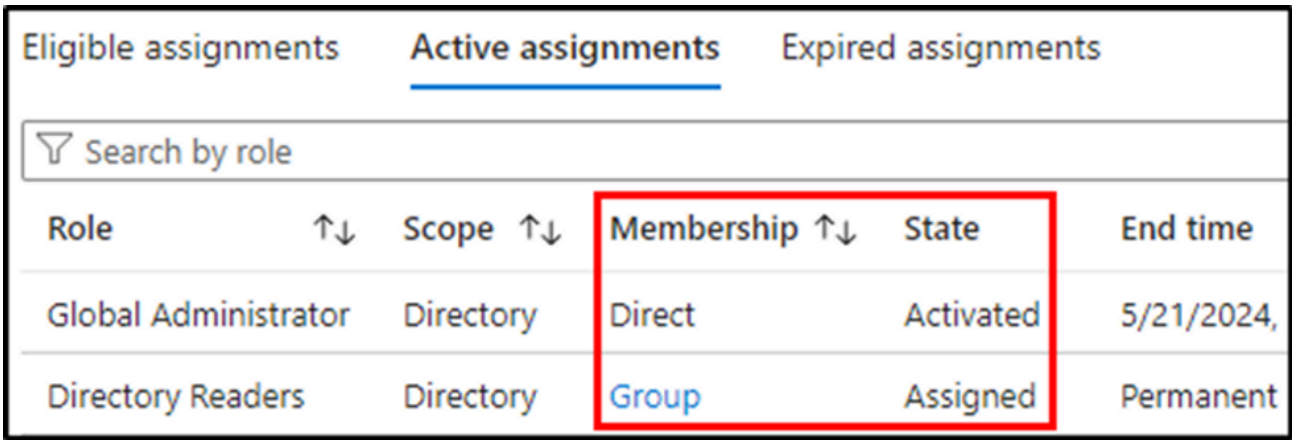


Figure 8

To recap. I now have an activated eligible assignment with direct membership and an assigned active assignment with group membership. Tell me you're following me now.



Summary

Ready everyone? Deep breath. PIM is an amazing security tool that I want to see in every single tenant I assess. In our Microsoft Cloud Security Assessment (MCSA) we've created an extensive section that fully enumerates privileged assignment and evaluates PIM implementation.

Role management is a different animal than several other sections of Entra. Day-to-day administration constantly changes privileges in Entra and it's easy for things to be overlooked. Regularly reviewing this configuration is crucial to maintaining a secure cloud environment.

For now, focus on implementing PIM and migrating accounts to use eligible assignments. Set membership expiration dates to help with account lifecycle management. Steer away from role-assignable groups for highly privileged roles and check all group owners to ensure membership is managed only by trusted accounts.

In part 2 of this series, I'll introduce role settings and explain how they can be used to improve upon eligible assignments. Role settings really shine when customizing the account activation process on a per-role basis.